

Eduardo Dias Santos

**Comparação entre Análise Sintática
Determinística e Classificação por Machine
Learning para Detecção de SQL Injection**

São Paulo

2026

Eduardo Dias Santos

Comparação entre Análise Sintática Determinística e Classificação por Machine Learning para Detecção de SQL Injection

Proposta de Trabalho de Conclusão de Curso apresentado ao SENAC Santo Amaro como requisito parcial para aprovação na disciplina de TCC1 do curso de Ciências da Computação.

SENAC – Serviço Nacional de Aprendizagem Comercial
Unidade Santo Amaro
Curso de Ciências da Computação

Orientador: Prof. ?

São Paulo
2026

Resumo

Este documento apresenta a proposta inicial do Trabalho de Conclusão de Curso (TCC1) desenvolvido no SENAC Santo Amaro. O objetivo deste trabalho é comparar técnicas de detecção de SQL Injection, analisando uma abordagem baseada em regras e outra baseada em aprendizado de máquina. A justificativa fundamenta-se na relevância dessa vulnerabilidade em aplicações web e na necessidade de métodos mais eficazes de detecção. A revisão bibliográfica aborda segurança de aplicações web, SQL Injection, análise sintática e aprendizado de máquina. Como solução, pretende-se implementar e avaliar os dois modelos, comparando seu desempenho. O trabalho está organizado em capítulos que apresentam a introdução, fundamentação teórica, desenvolvimento da proposta e referências.

Palavras-chave: SQL Injection. Machine Learning. Árvore Sintática Abstrata. Análise Sintática Determinística. Segurança Web.

Sumário

1	INTRODUÇÃO	4
1.1	Contexto	4
1.2	Justificativa	4
1.3	Objetivo	5
1.3.1	Objetivo principal	5
1.3.2	Objetivos secundários	5
2	REVISÃO BIBLIOGRÁFICA	6
2.1	Referencial teórico	6
2.2	Metodologia da pesquisa bibliográfica	6
2.3	Fundamentos	7
2.4	Trabalhos relacionados	7
2.4.1	Trabalho 1: [Título do trabalho]	7
2.4.2	Trabalho 2: Trident: Detecting SQL Injection Attacks via Abstract Syntax Tree-based Neural Network	7
2.4.3	Trabalho 3: A Hybrid Approach for Detecting SQL-Injection Using Machine Learning Techniques	8
3	DESENVOLVIMENTO	10
3.1	Solução proposta	10
3.2	Cronograma de trabalho	10
	REFERÊNCIAS	12

1 Introdução

1.1 Contexto

Os ataques cibernéticos representam um dos principais desafios da atualidade, afetando sistemas e usuários em escala global. Nesse cenário, invasores exploram vulnerabilidades presentes em aplicações com o objetivo de comprometer seu funcionamento e obter acesso não autorizado a dados sensíveis. Como consequência, tanto os responsáveis pelos sistemas quanto seus usuários podem ser prejudicados, seja pela indisponibilidade do serviço ou pelo vazamento de informações.

Entre as diversas ameaças existentes, os ataques por injeção destacam-se por sua relevância e recorrência. Essas vulnerabilidades estão listadas no Top 10 da OWASP, sendo a SQL Injection (SQLi) considerada uma das mais críticas, devido ao seu potencial de exploração e impacto nos sistemas afetados. ([OWASP, 2025](#))

1.2 Justificativa

Diante desse contexto, torna-se essencial o desenvolvimento de mecanismos eficazes para a detecção de ataques por injeção, especialmente SQLi, antes que o invasor consiga comprometer o sistema. Com o avanço das técnicas de Inteligência Artificial, surge a oportunidade de investigar se abordagens baseadas em aprendizado de máquina podem oferecer vantagens em relação a métodos tradicionais.

Assim, este trabalho propõe a comparação entre duas abordagens de detecção de SQL Injection: um modelo determinístico, baseado em regras, e um modelo probabilístico, fundamentado em técnicas de aprendizado de máquina. A partir dessa análise, busca-se identificar as vantagens e limitações de cada abordagem, contribuindo para que desenvolvedores e responsáveis por sistemas possam escolher a solução mais adequada às suas necessidades.

Além disso, durante o levantamento bibliográfico, observou-se que muitos trabalhos concentram-se no desenvolvimento de técnicas específicas de detecção, porém há uma quantidade reduzida de estudos voltados à comparação direta entre abordagens determinísticas e modelos baseados em aprendizado de máquina. Dessa forma, identifica-se uma lacuna na literatura quanto à análise comparativa dessas técnicas, especialmente em relação à precisão, desempenho e aplicabilidade em diferentes cenários. Assim, este trabalho busca contribuir para a área ao realizar uma avaliação comparativa entre esses métodos de detecção de SQL Injection.

1.3 Objetivo

Desenvolver um detector de SQL Injection baseado na análise de Árvore Sintática Abstrata e comparar o desempenho de duas abordagens de detecção: um analisador determinístico e um analisador probabilístico, por meio de avaliação experimental.

1.3.1 Objetivo principal

Comparar abordagens determinísticas e probabilísticas na detecção de SQL Injection, com base na análise de Árvores Sintáticas Abstratas (AST), por meio de avaliação experimental.

1.3.2 Objetivos secundários

Os objetivos secundários são desdobramentos do objetivo principal. Eles descrevem as etapas ou ações necessárias para atingir o objetivo principal. Devem ser mensuráveis e verificáveis.

- Implementar um analisador sintático capaz de gerar a Árvore Sintática Abstrata (AST) a partir de consultas SQL.
- Desenvolver um analisador determinístico baseado em regras estruturais da AST para identificar padrões de SQL Injection.
- Extrair características estruturais da AST e utilizá-las no treinamento de um modelo de aprendizado de máquina para detecção de consultas maliciosas.
- Realizar uma avaliação experimental comparando o desempenho do analisador determinístico e do modelo probabilístico.

2 Revisão Bibliográfica

A revisão bibliográfica tem como finalidade apresentar o embasamento teórico do trabalho, demonstrando o conhecimento do autor sobre o tema e identificando o estado da arte. Este capítulo deve ser organizado por conceitos e temas, construindo uma linha de argumentação que sustente a proposta do trabalho.

2.1 Referencial teórico

- Segurança de Aplicações Web
- SQL Injection (SQLi)
- Técnicas de detecção de SQL Injection
- Análise Sintática e AST (Árvore Sintática Abstrata)
- Aprendizado de Máquina na Segurança
- Comparação entre abordagens determinísticas e probabilísticas

2.2 Metodologia da pesquisa bibliográfica

A pesquisa bibliográfica foi realizada nas bases Google Scholar e IEEE Xplore, utilizando como string principal de busca:

```
("SQL Injection" OR SQLi) AND ("Machine Learning" OR "Deep Learning") AND ("Syntax Analysis" OR Parsing OR AST)
```

Além disso, foram utilizadas strings secundárias, como:

```
("SQL Injection Detection") AND ("Machine Learning") AND ("Deterministic Parsing" OR "Syntax-based Detection")
```

Foram selecionados artigos publicados entre 2021 e 2026, nos idiomas português e inglês, relacionados à detecção de ataques SQL Injection utilizando técnicas de Machine Learning, análise sintática, parsing e Árvores Sintáticas Abstratas (AST).

Durante o processo de seleção, foram excluídos trabalhos cujos títulos apresentavam baixa correlação com o tema proposto. Em seguida, foi realizada a leitura dos resumos para avaliar a relevância dos estudos em relação aos objetivos da pesquisa. Também foram descartados artigos que não abordavam técnicas relacionadas a AST, análise sintática ou métodos de detecção compatíveis com a proposta deste trabalho.

2.3 Fundamentos

Aprofunde os conceitos técnicos que serão utilizados na solução proposta. Diferentemente do referencial teórico (que apresenta conceitos gerais), os fundamentos devem detalhar as tecnologias, algoritmos, frameworks ou metodologias específicas que serão empregados no desenvolvimento.

Por exemplo:

- Se o trabalho utiliza aprendizado de máquina, explique os algoritmos escolhidos (árvores de decisão, redes neurais, SVM, etc.);
- Se o trabalho envolve desenvolvimento de software, descreva as tecnologias (linguagens, frameworks, bancos de dados);
- Se envolve análise de dados, explique as métricas e técnicas estatísticas que serão aplicadas.

Utilize figuras, diagramas e tabelas para ilustrar conceitos quando apropriado.

2.4 Trabalhos relacionados

Nesta seção, são apresentados três trabalhos recentes que abordam o desafio da detecção de ataques SQL Injection em aplicações web. A seleção prioriza métodos que, assim como esta pesquisa, utilizam técnicas de Machine Learning, análise sintática e Árvores Sintáticas Abstratas (AST) para identificar consultas maliciosas, buscando o equilíbrio entre alta precisão de detecção, redução de falsos positivos e eficiência computacional.

2.4.1 Trabalho 1: [Título do trabalho]

[Silva e Santos \(2022\)](#) abordou o problema de [descrever o problema — deve ser o mesmo ou muito similar ao seu]. Para resolvê-lo, os autores propuseram [descrever a solução]. A metodologia utilizada foi [descrever]. Os resultados mostraram que [descrever]. No entanto, a solução apresenta limitações como [descrever as lacunas que permanecem]. O presente trabalho diferencia-se por [explicar como sua proposta avança na resolução do mesmo problema].

2.4.2 Trabalho 2: Trident: Detecting SQL Injection Attacks via Abstract Syntax Tree-based Neural Network

[Li et al. \(2024\)](#) abordaram o problema da detecção de ataques SQL Injection em aplicações web, especialmente as dificuldades encontradas por métodos tradicionais ao identificar ataques ofuscados ou estruturalmente complexos. Para resolver esse problema,

os autores propuseram o Trident, uma abordagem baseada em Árvores Sintáticas Abstratas (AST) e redes neurais para análise estrutural de consultas SQL. A metodologia utilizada consistiu na transformação das consultas SQL em ASTs por meio de parsing sintático, permitindo que uma rede neural aprendesse padrões estruturais das consultas maliciosas e benignas. Os resultados mostraram que a utilização de informações sintáticas e hierárquicas das consultas SQL melhorou significativamente a capacidade de detecção quando comparada a abordagens puramente textuais. No entanto, a solução apresenta limitações como a dependência de modelos de aprendizado profundo e maior complexidade computacional durante o processamento e treinamento das redes neurais. O presente trabalho diferencia-se por investigar e comparar abordagens baseadas em análise sintática determinística e técnicas de Machine Learning, buscando avaliar não apenas a acurácia, mas também aspectos relacionados à interpretabilidade, complexidade e eficiência computacional na detecção de SQL Injection.

2.4.3 Trabalho 3: A Hybrid Approach for Detecting SQL-Injection Using Machine Learning Techniques

[Abdullah, Al-Janabi e Hussein \(2025\)](#) abordaram o problema da detecção de ataques SQL Injection em aplicações web, especialmente a dificuldade de identificar ataques desconhecidos e reduzir falsos positivos em sistemas tradicionais de detecção. Para resolver esse problema, os autores propuseram uma abordagem híbrida baseada em técnicas de Machine Learning, combinando algoritmos como Naive Bayes, LSTM e Random Forest para classificação de consultas SQL maliciosas e benignas. A metodologia utilizada consistiu na extração de características textuais das consultas SQL utilizando TF-IDF, seguida pelo treinamento e combinação dos modelos de aprendizado de máquina para melhorar a capacidade de detecção. Os resultados mostraram que o modelo híbrido alcançou elevada taxa de acurácia, superando modelos individuais e apresentando melhor desempenho na identificação de ataques SQL Injection, incluindo padrões desconhecidos. No entanto, a solução apresenta limitações como a dependência de grandes volumes de dados para treinamento, menor interpretabilidade dos modelos e ausência de análise estrutural detalhada das consultas SQL. O presente trabalho diferencia-se por investigar e comparar abordagens baseadas em análise sintática determinística e Árvores Sintáticas Abstratas (AST) com técnicas de Machine Learning, buscando analisar não apenas a precisão da detecção, mas também aspectos relacionados à interpretabilidade, complexidade computacional e análise estrutural das consultas SQL.

Uma tabela comparativa ajuda a sintetizar as diferenças entre os trabalhos:

Tabela 1 – Comparação entre trabalhos relacionados

Critério	Trabalho 1	Trabalho 2	Trabalho 3	Este trabalho
Objetivo	[resumo]	[resumo]	[resumo]	[resumo]
Tecnologia	[tecn.]	[tecn.]	[tecn.]	[tecn.]
Validação	[método]	[método]	[método]	[método]
Limitação	[limit.]	[limit.]	[limit.]	—

Fonte: Elaborado pelo autor (2025)

3 Desenvolvimento

Neste capítulo, apresenta-se a solução proposta para o problema identificado, bem como o cronograma de trabalho previsto para o desenvolvimento completo do projeto no TCC2.

3.1 Solução proposta

Descreva detalhadamente a solução que será desenvolvida para resolver o problema apresentado na introdução. A descrição deve incluir:

- **Visão geral da solução:** o que será desenvolvido (sistema, aplicativo, modelo, ferramenta, etc.);
- **Arquitetura:** como os componentes da solução se organizam e interagem;
- **Tecnologias e ferramentas:** quais linguagens, frameworks, bibliotecas, bancos de dados e ambientes serão utilizados, e por que foram escolhidos;
- **Funcionalidades principais:** o que a solução fará para atender aos objetivos;
- **Metodologia de desenvolvimento:** qual abordagem será utilizada (ágil, cascata, prototipação, etc.);
- **CrITÉrios de validação:** como será medido o sucesso da solução (métricas, testes, avaliação com usuários, etc.).

Utilize diagramas, fluxogramas ou mockups para ilustrar a solução. Exemplo de descrição de arquitetura:

A solução proposta consiste em uma aplicação web composta por três camadas: front-end desenvolvido em React.js, back-end em Node.js com Express, e banco de dados PostgreSQL. A comunicação entre front-end e back-end será feita por meio de uma API REST.

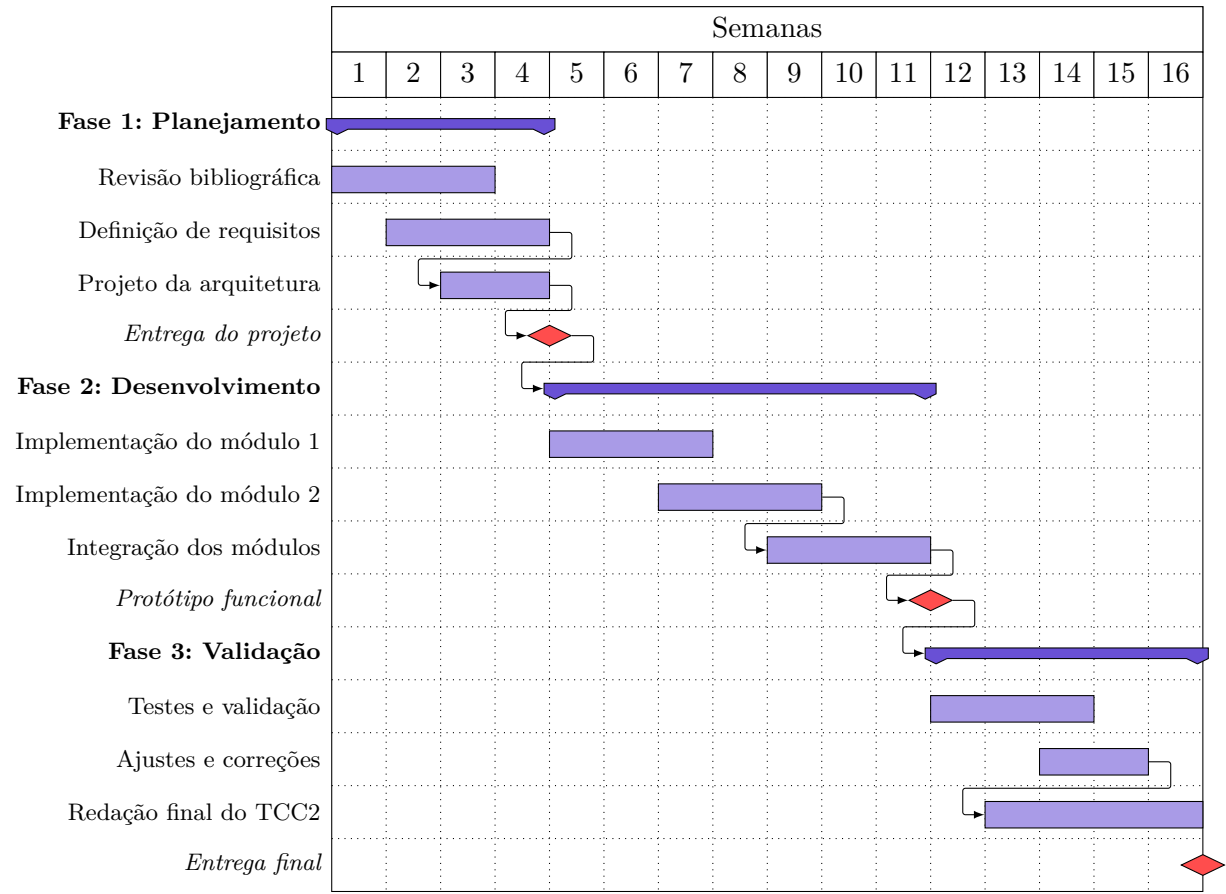
3.2 Cronograma de trabalho

O cronograma a seguir apresenta, no formato de diagrama de Gantt, as atividades previstas para o desenvolvimento do TCC2, distribuídas ao longo das semanas do semestre.

Instruções para personalização do cronograma:

- Ajuste o número de semanas conforme o calendário acadêmico do semestre;
- Modifique as atividades de acordo com as etapas do seu projeto;

Figura 1 – Cronograma de atividades – Diagrama de Gantt



Fonte: Elaborado pelo autor (2025)

- Os marcos (*milestones*) indicam entregas importantes — adapte-os às datas de avaliação;
- As setas entre atividades indicam dependências — uma atividade só inicia após a conclusão da anterior;
- Utilize o diagrama como ferramenta de acompanhamento: atualize-o a cada reunião com o orientador.

Referências

ABDULLAH, M.; AL-JANABI, S.; HUSSEIN, Z. A hybrid approach for detecting sql-injection using machine learning techniques. SCITEPRESS, 2025. 8

LI, Y. et al. Trident: Detecting sql injection attacks via abstract syntax tree-based neural network. ACM, New York, NY, USA, p. 1–5, 2024. 7

OWASP. *OWASP Top 10: 2025*. 2025. Acesso em: 24 abr. 2026. Disponível em: [<https://owasp.org/Top10/2025/>](https://owasp.org/Top10/2025/). 4

SILVA, J. C.; SANTOS, M. A. Aplicação de técnicas formais na validação de sistemas distribuídos. *Revista Brasileira de Computação Aplicada*, v. 14, n. 2, p. 45–58, 2022. 7